

Handout + Hausaufgabe: Sicherheits-Audit

Abgabe bis **Mittwoch, 15. Juli 2026, 18:00** im Hub: cockpit.automatisierbar.ch/vrv → Lernen → Modul 2 → Abgaben. Aufwand 60-90 min, Extra +30 min. Format: PDF, Fotos/Screenshots, Markdown oder Text.

Warum diese Aufgabe genau so (und warum ohne Claude)

Am 5.8. sagen wir einem Wirtschaftsprüfer Sätze wie **"unsere Geräte sind verschlüsselt, MFA ist überall Pflicht"**. Diese Sätze stehen schon im Security-Antwortpaket, und sie müssen für jeden von uns vier wirklich stimmen. Genau das prüfst du jetzt: an deinem eigenen Gerät, an deinen eigenen Konten. Claude kann das nicht für dich tun, nicht aus Prinzip, sondern praktisch: Claude sieht weder deine Festplatten-Verschlüsselung noch deine Account-Einstellungen. Und wer sein eigenes Setup einmal durchgeprüft hat, redet am 5.8. über MFA und Backups aus Erfahrung statt auswendig.

WICHTIG, vor dem Hochladen: Auf Screenshots niemals Passwörter, Recovery-Codes, vollständige Kontonummern oder private Mails zeigen. Vorher schwärzen. Die Abgaben sind für alle vier sichtbar. Es geht um den Nachweis der Einstellung ("FileVault: aktiviert"), nie um Inhalte.

Spickzettel: das Modell in 30 Sekunden

Drei Verantwortungsschichten: (1) Rechenzentrum = zertifizierter Anbieter, wir mieten. (2) Applikation + Betrieb + Daten unserer Lösung = wir, voll verantwortlich. (3) Büronetz, Endgeräte, M365 des Kunden = Kunde bzw. IT-Partner.

Vier Schutzringe: Identität (Passwort-Manager, MFA) → Gerät (Verschlüsselung, EDR, Updates) → Netz (Firewall, TLS) → Daten (Rollen, Audit-Log). Dahinter das Netz für den Ernstfall: Backup 3-2-1 mit getestetem Restore.

BEGRIFF	IN EINEM SATZ
MFA	Zweiter Faktor neben dem Passwort; gestohlene Passwörter allein werden wertlos
Passwort-Manager	Ein Tresor, überall einzigartige Passwörter; du merkst dir genau eins
Verschlüsselung at rest	Gespeicherte Daten ohne Schlüssel unlesbar (gestohlener Laptop = nutzlos)
TLS / in transit	Verschlüsselte Verbindung; das Schloss im Browser
EDR	Gerät wird auf verdächtiges Verhalten überwacht, nicht nur auf bekannte Viren gescannt
Firewall	Türsteher für Netzwerkverkehr; bei uns nur HTTPS öffentlich offen
VPN / Always On VPN	Automatischer Tunnel ins Firmennetz (Windows-Technik); unsere Lösung braucht keins
Zero Trust	Nicht das Netz vertraut dir; jede App prüft dich einzeln (Identität + Gerätezustand)
RBAC / Least Privilege	Rechte hängen an Rollen; jede Rolle bekommt nur das Minimum
Backup 3-2-1	3 Kopien, 2 Systeme, 1 extern; zählt erst mit getesteter Wiederherstellung
RTO / RPO	Wie schnell läuft es wieder / wie viel Datenverlust ist maximal drin
Patch-Management	Sicherheitsupdates zeitnah; kritische Lücken bei uns innert 48 Stunden

Sicherheits-Audit **deines** Setups

Pro Zeile: **Ampel** (GRÜN passt · GELB teilweise · ROT fehlt), **Beleg** (Screenshot-Nr.), bei GELB/ROT eine **Massnahme mit Datum**. Ehrliche Rots mit Massnahme sind der Sinn der Übung; ein geschöntes Audit ist wertlos.

Teil 1: Dein Gerät

PRÜFPUNKT	WO NACHSCHAUEN (MAC / WINDOWS)	AMPEL	BELEG	MASSNAHME + BIS WANN
1 · Festplatte verschlüsselt (FileVault / BitLocker)	Systemeinstellungen → Datenschutz & Sicherheit → FileVault · Windows: Datenschutz → BitLocker			
2 · Bildschirmsperre automatisch, Passwort sofort (max. 5 min)	Sperrbildschirm-Einstellungen			
3 · Betriebssystem aktuell, Auto-Updates AN	Softwareupdate / Windows Update			
4 · Malware-Schutz aktiv	Mac ab Werk (XProtect/Gatekeeper) · Windows: Sicherheit auf einen Blick			
5 · Arbeitest du im Alltag als Administrator? (Least Privilege)	Benutzerkonten anschauen			
6 · "Wo ist?" / "Mein Gerät suchen" aktiviert (Remote-Sperre)	Apple-ID / Microsoft-Konto			

Teil 2: Deine Konten (MFA-Inventar)

Mindestens diese sechs. Das private E-Mail-Konto ist der Generalschlüssel: darüber läuft jedes "Passwort vergessen". SMS-MFA zählt als GELB (App/Passkey = GRÜN). "Passwort im Browser gespeichert" ist kein Passwort-Manager (GELB).

KONTO	MFA AN? ART (APP/SMS/PASSKEY)	PASSWORT EINZIGARTIG + AUS MANAGER?	RECOVERY-CODES GESICHERT (WO)?	AMPEL	MASSNAHME + BIS WANN
Privates E-Mail					
Google / Apple-ID					
GitHub					
Microsoft 365					
E-Banking					
(eigene Wahl)					

Teil 3: Zugriffs-Landkarte (10 min, 5-8 Sätze)

Wer könnte heute auf was zugreifen, wenn dein Laptop JETZT gestohlen würde? Geh die Kette durch: Kommt der Dieb rein (Sperre? Verschlüsselung?)? Was ist im Browser eingeloggt? Wohin führt dein E-Mail-Konto? Was davon betrifft nicht dich, sondern Automatisierbar-Kunden?

5 Begriffe an deinem Beispiel

Je 2-3 Sätze, **zwingend am Beispiel aus deinem eigenen Audit** (nicht abstrakt, nicht aus dem Primer kopiert). So klingst du am 5.8. nach Erfahrung statt nach Auswendiglernen.

1. **MFA**: am Beispiel eines deiner Konten aus Teil 2 (welche Art, was sie stoppt).
2. **Verschlüsselung at rest**: am Beispiel deines Laptops (was passiert beim Diebstahl mit/ohne).
3. **Least Privilege**: am Beispiel deines Admin-Kontos oder eines Kontos, das mehr darf als nötig.
4. **Recovery / RPO**: Wenn dein Laptop heute stirbt: was wäre weg, seit wann ist die letzte Kopie? Das IST dein persönliches RPO.
5. **Phishing-Kette**: Wie käme ein Angreifer über DEIN E-Mail-Konto an ein zweites Konto, und welches Häkchen aus deinem Audit bricht die Kette wo?

Extra-Aufgabe (freiwillig, +30 min): Angriffs-Drehbuch auf Automatisierbar

Du bist der Angreifer und willst an Automatisierbar-Kundendaten. Halbe Seite: **(1)** Wen von uns vier greifst du an, warum ihn? **(2)** Mit welcher Mail/Nachricht (Vorwand, Absender, Zeitpunkt, gerne ausformuliert)? **(3)** Was willst du erbeuten? **(4)** An welcher unserer Massnahmen scheiterst du, wo kämst du durch? Nutze dein Insider-Wissen über unsere Tools, Kunden und Gewohnheiten, genau das macht echte Angriffe gefährlich. Beste Einreichung wird Anschauungsmaterial für die 5.8.-Vorbereitung.

Abgabe, Schritt für Schritt

1. Alles in eine Datei packen, wenn möglich (PDF am einfachsten: Fotos der ausgefüllten Tabellen + Text). Mehrere Dateien gehen auch.
2. Hub öffnen: **cockpit.automatisierbar.ch/vrv** → Lernen → Karte Modul 2 → **Abgaben ansehen** → Name wählen, Datei hochladen, kurzer Kommentar.
3. **Frist: Mittwoch, 15. Juli 2026, 18:00**. Abgaben sind für alle vier sichtbar; die Ampeln besprechen wir kurz in der nächsten Session.
4. Rote Punkte müssen nicht vor der Abgabe gefixt sein, aber jede rote Zeile braucht eine Massnahme mit Datum.

Merksatz für den 5.8.: Der Prüfer testet nicht unser Sicherheits-Niveau, er testet, ob wir flunkern. Ehrliche Antworten mit klaren Grenzen schlagen jede aufgeblasene Behauptung.